

VULNERABILITY ASSESSMENT REPORT

Overview

I conducted vulnerability assessment and runtime testing for

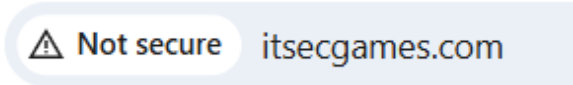
🌐 MME | Security Audits & Training this comprises of me scanning and analyzing the website for security issues then compiling a report with the issues picked up, what level of risk they carry and what the remediation strategies are.

Website Issues Detail

Website Header Not Secure

A simple website search for itsecgames.com shows the header is not secure. This essentially means the website is using http instead of https. The difference between the two is https has a transport layer which makes browsing secure. This happens because your website doesn't have a valid SSL certificate therefore its not on the secure layer.

Consider screenshots below.

A screenshot of a web browser's address bar. On the left, there is a warning icon (a triangle with an exclamation mark) followed by the text "Not secure". To the right of this, the domain "itsecgames.com" is displayed.

⚠ Not secure or Dangerous



Do not enter any personal information on this page. If possible, do not use the site.

Not secure: Proceed with caution. Site connection isn't private. Someone can find the information you send or get through this site.

Dangerous: Do not use this site. If you get a full-page red warning screen, the site is flagged as unsafe by [Google Safe Browsing](#) . The site threatens your privacy and security which can abuse any information it receives, and could attempt to install harmful software.

Recommendation : Obtain a SSL certificate then install it, There are multiple places to get one, free or paid. SSL certificates can be obtained from your hosting provider, certificate authority or obtained for free from Let's Encrypt however they expire after 3 months and can

be renewed. It is worth noting that certificates even paid expire after 12 months so these need to be renewed.

Port Exposure Analysis

I then scanned your website to see if there are any open ports which may pose a security threat to the organization.

While conducting port exposure analysis I saw three ports as below which are opened in your website.

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 6.7p1 (protocol 2.0)
80/tcp	open	tcpwrapped	
443/tcp	open	tcpwrapped	

Level of Risk: High

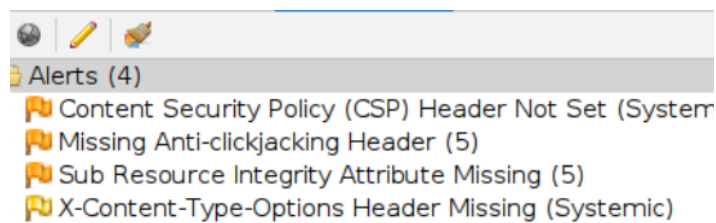
Impact: Leaving port 22 open makes your server a target for automated, relentless, unauthorized login attempts.

Recommendation : Use a VPN: Only allow access to port 22 through a VPN

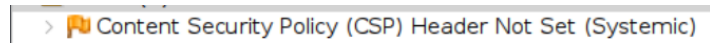
Port 22 (SSH) should generally not be open to the public internet because it is a prime target for brute-force attacks. While necessary for remote management, it should be secured by restricting access to specific IP addresses, using key-based authentication instead of passwords, or changing the default port.

PASSIVE SCANNER

I passive scanned your website and found issues which I will explain and advise on how to fix them. passive scanning is a defensive and safe strategy for you as it's a non-intrusive security tool that monitors network traffic or analyzes data to identify assets, vulnerabilities, and misconfigurations without directly interacting with or sending packets to the target, while vulnerabilities exist on your website, the scanner just looks at them instead of taking advantage, however, be warned that someone else may not just look but actually attack the website therefore you need to implement the fixes recommended to strengthen your security posture.



1. Content Security Policy(CSP) Header Not Set(Systemic)



Risk- this leaves the website vulnerable to XSS (Cross-Site Scripting), clickjacking, and cross-site leak vulnerabilities

Summary: Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page.

Impact: An exploit can lead to Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware.

Level of Risk - Medium

Recommendation: Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

Since your server is Apache this is how to do it.

In Apache configuration (.htaccess or httpd.conf):

Header set Content-Security-Policy "default-src 'self'; script-src 'self'; object-src 'none';"

Because this is server-level, it automatically applies to:

- HTML pages
- APIs
- static files
- 404 responses

2. Missing Anti-clickjacking Header



Summary: The website is missing a security setting that prevents a type of attack called *clickjacking*. In this attack, a malicious site could secretly load our website inside a hidden frame and trick users into clicking buttons or links without realizing it.

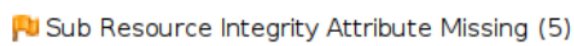
Impact: If exploited, attackers could potentially trick users into performing unintended actions on the website, such as clicking buttons, submitting forms, or changing settings.

Level of Risk-Medium

Recommendation: Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app.

If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.

3. Missing SRI Attribute



Sub Resource Integrity Attribute Missing

Summary: The integrity attribute is missing on a script or link tag served by an external server.

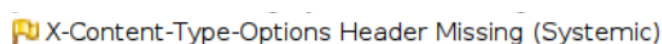
Impact: If exploited an attacker who has gained access to the server can inject malicious content

Level of Risk: Medium

Recommendation: Provide a valid integrity attribute to the tag.

To set the X-Frame-Options header to "SAMEORIGIN" in Apache, you need to add the following line to your server configuration files (like httpd.conf, within a <VirtualHost> block, or a .htaccess file): - Header always set X-Frame-Options "SAMEORIGIN"

4. X-Content-Type-Options Header Missing



Summary: The website is missing a security setting that tells web browsers to strictly follow the declared file type of website content. Without this setting, some browsers may try to "guess" the type of content being delivered, which could potentially allow malicious files to be interpreted and executed in unintended ways.

Impact: If exploited, attackers could attempt to trick the browser into interpreting content incorrectly, which may increase the risk of certain attacks such as malicious scripts being

executed.

Level of Risk: Low

Recommendation: Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages.

If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.

END